

sifr.kit 보안정책서



작성자 : 신승혁 (shinbaad@gmail.com)

문서버전	설 명	날 짜	확 인
1.0	최초작성	2025.12.01	신승혁

Contents

문서 구성	3
1 개요	4
2 암호모듈 명세	5
3 암호모듈 인터페이스	6
4 역할, 서비스 및 인증	7
5 소프트웨어 보안	9
6 운영환경	10
7 중요 보안매개변수 관리	11
8 자가시험	12
9 생명주기 보증	13
10 기타 공격에 대한 대응	14

문서 구성

본 문서는 sift.kit 보안정책에 대하여 기술한다.

1 개요

본 문서는 암호모듈 보안 요구사항 KS X ISO/IEC 19790:2015와 암호모듈 시험 요구사항 KS X ISO/IEC 24759:2015에서 정의한 보안수준 1의 기준에 따라 sifr.kit v1.0 암호모듈의 구성요소 및 작동 방법에 대하여 기술한다.

표 1.1. 암호모듈 개요

암호모듈 개요		
모듈유형	소프트웨어 모듈	
보안수준	보안수준 1	
작성기준	보안 요구사항	KS X ISO/IEC 19790:2015
	시험 요구사항	KS X ISO/IEC 24795:2015

2 암호모듈 명세

sifr.kit은 런타임 라이브러리 형태의 범용 소프트웨어 모듈이다. 지원하는 검증 대상 암호 알고리즘은 [그림 1]과 같이 블록암호(ARIA, LEA, SEED, HIGHT), 해시 함수(SHA2, LSH256, LSH512), 메시지 인증(HMAC) 그리고 난수발생기(CTR_DRBG)이며, 비검증대상 암호알고리즘은 제공하지 않는다.



그림 1. 검증대상 암호 알고리즘

표 2.1 암호모듈 유형

암호모듈명	sifr.kit		
버전	v1.0		
제작	국립금오공과대학교 산학협력단 신승혁		
보안수준	보안수준 1		
암호모듈 유형	소프트웨어 모듈 (동적라이브러리)		
암호서비스	블록암호	ARIA 128/192/256	ECB, CBC, CFB(1,8,64,128bit), OFB, CTR
		LEA 128/192/256	ECB, CBC, CFB(1,8,64,128bit), OFB, CTR
		SEED 128	ECB, CBC, CFB(1,8,64,128bit), OFB, CTR
		HIGHT 128	ECB, CBC, CFB(1,8,32, 64bit), OFB, CTR
	해시함수	SHA2	256 bit
		LSH256	224,256 bit
		LSH512	224,256,384,512 bit
	메시지인증	HMAC	SHA2 256 bit
운영환경	난수발생기	SEED	CTR_DRBG (유도함수 사용)
	MS Window 10 64bit		sifr.kit.x86.dll, sifr.kit.x86_64.dll
	Ubuntu 22.04 LTS 64bit		sifr.kit.x32.so, sifr.kit.x64.so
	Ubuntu 22.04 LTS 64bit for IoT		sifr.kit.ha64.so
암호모듈 형상데이터 경로	국가정보원 홈페이지 > 주요업무 > 암호모듈 검증 > 검증필 암호모듈 목록 > sifr.kit v1.0 형상데이터		

3 암호모듈 인터페이스

sifr.kit의 모든 정보 흐름은 논리적 인터페이스를 통해 수행되며, 직접적인 물리적 인터페이스는 제공하지 않는다. sifr.kit의 논리적 인터페이스는 데이터 입력, 데이터 출력, 제어 입력 그리고 상태 출력 4가지이다. [표 3.1]은 암호모듈의 인터페이스를 설명한다.

표 3.1. 암호모듈 인터페이스

항 목	PE03.01	
구 분	논리적 인터페이스	물리적 인터페이스
데이터 입력	- 외부로부터 입력되는 제어 정보를 제외한 모든 데이터를 데이터 입력 인터페이스를 통해 입력 - 데이터 입력 : 평문 및 암호문, 중요보안 매개변수 - sifr.kit은 API의 함수 인자를 이용하여 데이터 입력을 수행	키보드 마우스
데이터 출력	- 외부로 출력하는 상태 정보를 제외한 모든 데이터는 데이터 출력 인터페이스를 통해 출력 - 출력 데이터 : 평문 및 암호문 - sifr.kit은 API의 함수 인자를 이용하여 데이터 출력을 수행	모니터 UART
제어 입력	- 라이브러리의 API호출 시 암호모듈 시작/종료, 암호 운영을 위하여 전달되는 값 - sifr.kit의 동작을 제어하기 위하여 암호 관리자나 사용자에게 의하여 모듈로 입력되는 모든 API 함수 호출 입력	키보드 마우스
상태 출력	- 외부로 출력하는 상태정보는 상태 출력 인터페이스를 통해 출력 - 상태정보를 표시하기 위해서 사용되는 모든 출력 신호, 표시기 및 상태 데이터 등 - sifr.kit은 API 함수의 리턴 값으로 출력되며, 각 리턴 값을 통해 함수의 수행 성공, 실패 여부를 제공	모니터 UART

4 역할, 서비스 및 인증

sifr.kit은 소프트웨어 라이브러리 형태의 암호모듈로서 여러 응용에게 범용적인 암호 서비스를 제공하는 것을 목표로 한다. 또한 보안수준이 높기 때문에 자체적인 인증 메커니즘을 탑재하지 않고 운영환경에서 제공하는 메커니즘을 활용한다. 이 암호모듈은 관리자와 사용자 역할을 지원하며, 각 운영자는 논리적으로 구분된다. 암호모듈은 검증대상 서비스만을 포함하고 있으며, 일반 서비스인 검증대상 암호알고리즘을 이용하는 보안 서비스, 버전 출력 서비스, 자가시험 수행 서비스, 상태 출력 서비스, 제로화 서비스를 제공하며, 우회기능, 자가초기화된 출력기능, 소프트웨어/펌웨어 로딩과 같은 서비스는 제공하지 않는다

4.1 역할

sifr.kit 서비스를 이용하는 암호모듈은 [표 4.1.1]과 같이 관리자와 사용자로 역할을 구분한다.

역 할	역할	권한 (논리적 분류)
관리자	암호모듈의 초기화 구성, 자가시험, 무결성검증 등의 작업을 통해 모듈이 제공하는 암호 서비스를 접근 및 사용할 수 있도록 준비, 암호모듈 적용, 시험, 암호모듈 배포	sifr.kit에 대한 완전한 접근권한 부여 (설치, 제거, 삭제 등)
사용자	암호모듈의 초기화 구성, 자가시험, 무결성검증 등의 작업을 통해 모듈이 제공하는 암호 서비스를 접근 및 사용할 수 있도록 준비, 외부로부터의 중요보안매개변수, 암호 서비스를 사용할 수 있는 일반 운영자의 역할, sifr.kit을 사용	sifr.kit의 운영에 대한 접근권한 부여

4.2 서비스

서비스 분류	API 명칭	동작내용	인가된 역할
초기화	int32_t __sifr_initia()	암호모듈 초기화	관리자/사용자
종료화	int32_t __sifr_finelia()	암호모듈 종료화	관리자/사용자
상태확인	int32_t __sifr_status()	현재 상태 확인	관리자/사용자
모듈이름확인	int8_t* __sifr_module()	모듈이름 확인	관리자/사용자
버전확인	int8_t* __sifr_version()	버전확인	관리자/사용자
저작자확인	int8_t* __sifr_author()	저작자 확인	관리자/사용자
메모리 삭제	int32_t __sifr_mem_clear(int8_t* p, uint32_t sz)	메모리 삭제	관리자/사용자
자가시험	int32_t __sifr_self_check()	핵심기능시험 무결성검증시험	관리자/사용자
난수발생기	int32_t __sifr_random(int32_t isz, uint8_t* out, int32_t* osz)	난수생성	관리자/사용자
메시지인증	int32_t __sifr_hmac(uint8_t* key, int32_t ksz, uint8_t* in, int32_t isz, uint8_t* out, int32_t* osz)	HMAC 연산 수행	관리자/사용자
블록암호	int32_t __sifr_crypt(uint8_t* cmd, int32_t sz, uint8_t* key, int32_t ksz, uint8_t* iv, int32_t ivsz, uint8_t* in, int32_t isz, uint8_t* out, int32_t* osz)	블록암호 암호화	관리자/사용자

	<code>int32_t isz, uint8_t* out, int32_t* osz)</code>	/복호화 수행	
해시함수	<code>int32_t __sifr_hash(uint8_t* cmd, int32_t sz, uint8_t* in, int32_t isz, uint8_t* out, int32_t* osz)</code>	해시 수행	관리자/사용자

5 소프트웨어 보안

sifr.kit 암호모듈은 비인가된 주체로부터 암호 모듈 자체가 훼손되거나 다른 모듈로 대체 불가능 하도록 하기 위하여 무결성 검증방법을 이용하여 보호한다.

무결성 시험은 검증대상 암호알고리즘 HMAC_SHA2 를 사용하여, 사전에 생성한 무결성 결과 값과 비교하여 무결성 값의 일치 여부를 확인한다.

6 운영환경

sifr.kit 암호모듈은 범용 운영체제에서 동작하는 소프트웨어 라이브러리이다.

운영체제	버전	플랫폼/아키텍처	라이브러리 bit	암호모듈 이름
Windows	10	x64	32bit	sifr.kit.x86.dll
			64bit	sifr.kit.x86_64.dll
Ubuntu	22.04	x86_64	32bit	sifr.kit.x32.so
			64bit	sifr.kit.x64.so
		aarch64	64bit	sifr.kit.ha64.so

7 중요 보안매개변수 관리

sifr.kit 암호모듈의 공개보안 매개변수(PSP, Public Security Parameter)와 핵심보안 매개변수(CSP, Critical Security Parameter)는 인가되지 않은 접근, 사용, 노출, 변경 및 대체로부터 보호된다.

표 7.1. 중요보안 매개변수

구분	알고리즘	중요 보안매개변수, SSP	
		핵심보안매개변수, CSP	공개보안매개변수, PSP
블록암호	ARIA	비밀키/라운드키	iv/카운터
	LEA	비밀키/라운드키	iv/카운터
	SEED	비밀키/라운드키	iv/카운터
	HIGHT	비밀키/라운드키	iv/카운터
해시함수	SHA2	-	-
	LSH256	-	-
	LSH512	-	-
인증	HMAC	비밀키	-
난수발생기	CTR_DRBG	entropy 내부상태 (Key, v) nonce	개별화 문자열 추가입력

분류	암호 알고리즘	핵심 보안매개변수 (CSP)	생성	설정	주입	출력	저장	제로화
블록암호	ARIA	비밀키	○	×	×	×	×	○
		라운드 키	○	×	×	×	×	○
	LEA	비밀키	○	×	×	×	×	○
		라운드 키	○	×	×	×	×	○
	SEED	비밀키	○	×	×	×	×	○
		라운드 키	○	×	×	×	×	○
	HIGHT	비밀키	○	×	×	×	×	○
		라운드 키	○	×	×	×	×	○
메시지 인증	HMAC	비밀키	○	×	×	×	×	○
난수발생기	CTR_DRBG	entropy	○	×	×	×	×	○
		내부상태 Key	○	×	×	×	×	○
		내부상태 v	○	×	×	×	×	○
		nonce	○	×	×	×	×	○

8 자가시험

sift.kit 암호모듈은 암호 기능의 정상적인 수행을 보장하기 위하여 암호모듈에 전원이 인가될 때, 시작과 함께 동작 전 자가 시험을 수행한다. 동작 전 자가시험은 무결성 검증 시험으로 진행하며, 핵심기능 시험으로 조건부 암호알고리즘 KAT 시험을 수행한다. 동작 전 자가시험은 암호모듈이 메모리에 적재되어 자동으로 진행되며, 이과정에서 어떠한 암호 연산도 수행되지 않는다. 동작 전 자가시험은 사용자의 임의의 입력과 무관하게 수행되고 시험 도중에는 암호관리자 및 사용자의 인터페이스를 통한 그 어떤 개입도 할 수 없다.

세부시험	구분	수행 내용	수행시점
동작 전 자가시험		동작 전 핵심기능 시험 (조건부 암호알고리즘 KAT)	암호모듈 초기화 시 동작
		암호모듈 무결성 시험	암호모듈 초기화 시 동작
조건부 자가시험		조건부 암호알고리즘 KAT시험	동작 전 핵심 기능 시험으로 수행
		잡음원 건전성 시험	암호 서비스 운영 중 (난수발생기 실행시)
	주기적 자가시험	암호알고리즘 KAT 시험	사용자의 요청이 있을 시
		암호모듈 무결성 시험	
		잡음원 건전성 시험	

9 생명주기 보증

sifr.kit 암호모듈의 형상관리는 형상항목의 변화를 일관성 있게 관리함으로써 생산성 극대화 및 높은 품질보증 수준을 갖는 제품을 개발함에 목적이 있다. 또한 형상관리를 통해 주어진 시점의 제품 형상을 식별하며 형상 변경을 체계적으로 제어하며, 개발기간 동안 형상 항목에 대한 무결성 및 추적 가능성을 보장한다. 이러한 목적과 기능을 충족시키기 위해 인터넷으로부터 격리된 형상관리 서버로서 git 서버를 이용한다.

내부배포	내부배포는 다음과 같은 경우 배포를 시작한다. 1. 사용자로부터 sifr.kit 사용요청이 발생 할 때 2. 사용목적이 명확한 경우 배포 a. 암호 응용프로그램을 개발하기 위하여 사용자가 요청할 때 b. 사용자가 암호모듈의 적용처를 명확하게 구성하여 요청할 때 c. 사용자가 배포가 필요하다고 판단한 경우 3. 모든 배포는 배포자, 시간, 배포처, 사용목적 등을 기록한 배포목록을 작성해야 한다.
외부배포	외부배포는 다음과 같은 경우 배포를 시작한다. 1. 사용자로부터 sifr.kit 사용요청이 발생 할 때, 관리자는 [붙임 1]의 암호모듈 사용요청서를 작성하여 사용처 및 사용 목적을 명시한 후 배포한다.

10 기타 공격에 대한 대응

sifr.kit 암호모듈은 버퍼오버플로우 방지를 위하여 버퍼관리 함수에 입력되는 버퍼의 크기등을 입력하도록 재정의된 함수를 사용하며, 취약점이 발생하지 않도록 시스템에서 제공하는 취약한 함수 (예, strlen, memcpy, memset 등) 를 재정의하여 구현한다.

End